

CyberDefense Pro 2.0

2.2.4 Threat Modeling Facts

This lesson covers the following topics:

- Threat modeling
- The five steps of threat modeling

Threat Modeling

Threat modeling is designed to identify the principal risks and tactics, techniques, and procedures (TTPs) that a system may be subject to by evaluating the system both from an attacker's point of view and the defender's point of view. For each scenario-based threat situation, the model asks whether defensive systems are sufficient to repel an attack perpetrated by an adversary with a given level of capability. Threat modeling can be used to assess risks against corporate networks and business systems, and it can also be performed against more specific targets, such as a website or software deployment. The outputs from threat modeling can be used to build use cases for security monitoring and detection systems. Threat modeling is typically a collaborative process with inputs from various stakeholders. In addition to cybersecurity experts with knowledge of the relevant threat intelligence and research, stakeholders can include non-experts, such as users and customers, and persons with different priorities on the technical side, such as those who represent financial, marketing, and legal concerns.

The Five Steps of Threat Modeling

There are five basic threat modeling steps.

Adversary Capability Analysis

During the adversary capability analysis step, identify potential threat sources, determine how likely these attacks are, and consider the adversary's capabilities. Threat actors or

possible threat sources could specifically target the organization, or the attack could be convenient or opportunistic. Depending on the nature of the organization, sources could include nation-state attackers, organized crime, or hacktivists.

Total Attack Surface Analysis

The total attack surface refers to all ways an adversary could access the system. When determining the total attack surface, take inventory of the entire network. The inventory should include hardware, software, and the capabilities and processes of each device.

Attack Vector Analysis

An attack vector is a specific point to exploit on the total attack surface. MITRE provides three main categories for attack vectors:

Category	Description
Cyber	Hardware or software is used for an attack. Examples include portable storage devices, messaging apps, unauthorized devices, and compromised user accounts.
Human	An attacker uses social engineering techniques such as impersonating or coercing an employee inside the organization.
Physical	The attacker with malicious intent gains physical access to the target location.

Impact Analysis

An impact analysis evaluates the cost of an attack. It determines how an organization would be impacted if a threat were not stopped.

Consideration	Description
Financial cost	Financial cost includes: • System repair • Fines • Contract penalties • Additional staffing
Impact of system downtime	Impact of system downtime: • Lost customers • Contract penalties • Refunds • Additional staffing or overtime
Non-financial costs	Non-financial costs include: • Reputation • Customer satisfaction • Customer confidence

Likelihood Analysis

The likelihood analysis determines the probability that an attack will occur. When considering the likelihood of a threat, you will want to consider the following:

- Attacker's motivation
- Emerging capabilities
- Effectiveness of attacks
- The annual rate of occurrence (ARO)

Copyright © CompTIA, Inc. All rights reserved.